LITERATURE SURVEY

Trust-Aware Agentic AI for Autonomous Cyber Incident Response and Resilient Recovery

Project ID 221	**Course** UE24CS320A – Capstone Project	**Review** Phase-I · Review-1
Project Guide Dr. Geetha Dayalan	**Institution** PES University	**Survey focus** Incident response workflows

Research Paper Under Review

"Do You Play It by the Books? A Study on Incident Response Playbooks and Influencing Factors"

Authors: Daniel Schlette, Philip Empl, Marco Caselli, Thomas Schreck, and Gunther Pernul
Publication: 2024 IEEE Symposium on Security and Privacy
DOI: 10.1109/SP54263.2024.00060

Abstract of the Survey

This literature survey reviews a 2024 empirical study of cybersecurity incident response playbooks. The paper examines how playbooks are structured and used, and how organizational and external conditions influence their design. Its findings are relevant to the capstone project because they highlight the value of structured response workflows, automation, and organization-specific adaptation. The reviewed work does not, however, define a quantitative trust model for backups or an evidence-based recovery-point selection mechanism. These differences establish a clear connection between the paper and the proposed trust-aware recovery system.

1. Problem Addressed

Incident response playbooks provide structured procedures that guide security teams and automated systems through actions required to handle cybersecurity incidents. They can combine threat-related information with organization-specific procedures, tools, and operational requirements. However, organizations differ in their infrastructure, security products, personnel, policies, and available resources. A playbook created for one environment may therefore be unsuitable for direct use in another.

The paper investigates two central questions: (i) what characteristics are present in community incident response playbooks, and (ii) which factors influence incident response processes and organization-specific playbooks? It also addresses the lack of a consistent understanding of what constitutes a playbook and how playbook workflows should be represented.

2. Research Methodology

The authors employ a mixed-methods research design that combines analysis of collected playbooks, an online survey, and interviews with security professionals. The empirical data collection and analysis took place between May 2022 and February 2023.

Research component	Description
Playbook collection	The researchers initially gathered 1,347 playbooks from 18 sources. The final analysis covered 1,217 playbooks from 14 sources.
Workflow analysis	Custom Python connectors and Jupyter Notebooks supported processing. The study examined workflow steps and action patterns, with manual review where automated analysis was insufficient.
Online survey	147 participants provided information about playbook purposes, formats, operational use, and organizational practices.
Expert interviews	Nine security professionals discussed practical use, adaptation, and factors shaping incident response.

Research component	Description
Statistical analysis	Stata was used to analyze survey responses. NLP and exploratory machine-learning techniques were used during playbook analysis.

3. Technologies and Analytical Techniques

The study is primarily an empirical analysis rather than the proposal of a new incident-detection or recovery algorithm. Its technical methods include Python-based data collection and processing, Jupyter Notebooks, and natural language processing techniques such as tokenization, stemming, and dependency parsing. The authors also explored clustering, text vectorization, dimensionality reduction, and topic modelling to identify patterns in workflow descriptions. Because the resulting clusters and topics were not sufficiently meaningful for consistent interpretation, manual classification was used for parts of the analysis. Stata supported statistical analysis of the survey data.

4. Key Findings and Results

The analysis shows that playbooks contain different types of workflow activities, including investigation, utility, logic, ticketing, and countermeasures. Investigation activities form the largest category in the analyzed workflow steps. The study also reports that 96.93% of the analyzed workflow steps were automated, while 3.07% involved human interaction. These figures describe the playbooks examined in this study and should not be interpreted as a universal rate for all incident response operations.

Observation	Reported result	Interpretation
Playbook purposes	Documentation: 79.7%; automation: 52.8%; compliance: 51.2%; onboarding: 44.7%.	Playbooks support operational consistency as well as knowledge capture and compliance.
Playbook formats	Text: 76.7%; graphical: 46.8%; code-based: 38.7%.	Playbooks are represented in multiple forms rather than through one universal format.
Operational use	Investigation/analysis: 83.6%; countermeasures/mitigation: 68.9%; alerting/ticketing: 60.7%.	Playbooks span analysis, mitigation, and coordination activities.
External playbooks	40% used external playbooks; these were modified for organizational context.	Community playbooks generally require adaptation before operational use.
Influencing factors	Technology: 78.9%; IR directives: 69%; people: 66.2%; standards: 55.6%; laws/regulations: 52.1%.	Both technical and organizational conditions shape response workflows.

5. Factors Influencing Incident Response

The paper groups influencing factors into external and internal categories. External factors include attacker characteristics, industry standards and guidelines, laws and regulations, and business or supply-chain relationships. Internal factors include incident response directives, data operations, personnel and security culture, security teams, technology infrastructure, and security tools. The interviews emphasize that operational decisions depend on the organization's actual capabilities and constraints. For example, the appropriate countermeasure may vary according to the tools available, staff capacity, permissions, and use of outsourced services.

6. Limitations and Research Gaps

The study focuses on playbook characteristics and the organizational context in which incident response procedures are used. It does not propose a quantitative method for measuring the trustworthiness of backup recovery points, determining whether a backup has been contaminated, or selecting the safest recovery point from competing candidates. It also does not develop a dependency-aware backup restoration algorithm or a post-recovery verification mechanism.

The paper notes challenges associated with heterogeneous and inconsistent playbook data and the limited success of automated clustering and topic-modelling approaches. Its findings are based on selected publicly available sources, a survey sample, and interviews with nine professionals. These characteristics should be considered when generalizing the results to other organizations and operational settings.

The broader research opportunity is to improve standardization, sharing, and context-aware adaptation of response procedures. For the capstone problem, a further gap is the need to connect incident-response workflows to evidence-based recovery decisions, where the safety of each recovery point is explicitly assessed.

7. Relevance to the Proposed Capstone Project

The reviewed paper supports the motivation for structured, automated, and organization-aware cybersecurity response. Its findings indicate that incident response procedures must account for the organization's technology, policies, personnel, external obligations, and operational dependencies. This is directly relevant to the proposed project, **“Trust-Aware Agentic AI for Autonomous Cyber Incident Response and Resilient Recovery.”**

The proposed capstone extends the workflow perspective toward recovery-point trust assessment. It combines security alerts and logs, cyber threat intelligence, attack timelines, service-dependency information, and backup metadata to calculate a Recovery Trust Score (RTS) for each recovery point. Recovery points are classified as TRUSTED, UNCERTAIN, or UNTRUSTED. A policy gate can reject unsafe backups or actions, while the recovery planner orders restoration according to service dependencies.

High-impact actions require human approval, and trust can be recalculated when new evidence becomes available.

Thus, the reviewed paper contributes an understanding of incident response playbook structure and contextual influences, whereas the proposed project focuses on evidence-based trust scoring, safe backup selection, policy-constrained planning, and resilient system recovery. The proposed RTS and recovery workflow are project-specific extensions; they are not methods introduced by the reviewed paper.

8. Conclusion

Schlette et al. demonstrate that incident response playbooks are valuable for documenting, automating, and coordinating cybersecurity processes, but their effectiveness depends on adaptation to organizational context. The study highlights the diversity of playbook structures and the influence of technical, human, regulatory, and operational factors. For the proposed capstone, the paper provides a foundation for designing structured response workflows while leaving open the specific problem of measuring backup trust and selecting safe recovery points. Addressing this gap is central to the project's trust-aware recovery approach.

Reference

[1] D. Schlette, P. Empl, M. Caselli, T. Schreck, and G. Pernul, “Do You Play It by the Books? A Study on Incident Response Playbooks and Influencing Factors,” *2024 IEEE Symposium on Security and Privacy*, 2024, doi: 10.1109/SP54263.2024.00060.

LITERATURE SURVEY

Trust-Aware Agentic AI for Autonomous Cyber Incident Response and Resilient Recovery

Project ID	Course	Review
221	UE24CS320A – Capstone Project	Phase-I · Review-1
Project Guide	**Institution**	**Survey focus**
Dr. Geetha Dayalan	PES University	Cyber event recovery

Research Document Under Review

"Guide for Cybersecurity Event Recovery"

Authors: Michael Bartock, Jeffrey Cichonski, Murugiah Souppaya, Matthew Smith, Greg Witte, and Karen Scarfone
Publication: NIST Special Publication 800-184, December 2016
Publisher: National Institute of Standards and Technology (NIST)
DOI: 10.6028/NIST.SP.800-184

Abstract of the Survey

This literature survey reviews NIST SP 800-184, a technology-neutral guide for preparing, executing, measuring, and improving recovery from cybersecurity events. The publication emphasizes advance recovery planning, asset and dependency identification, customized recovery playbooks, validation exercises, and continuous improvement. It is especially relevant to the proposed capstone because it explicitly discusses backup integrity checks, confidence in backup quality, dependency maps, restoration priorities, and post-restoration security validation.

1. Problem Addressed

The publication addresses the difficulty organizations face in restoring critical capabilities and services after cybersecurity events. Recovery is often more complex than rebuilding a system or restoring data from a backup because it involves interconnected people, processes, technologies, business functions, and external services. Recovery guidance was historically distributed across security, contingency, disaster recovery, and business continuity documents, making it difficult for organizations to develop a coherent and tested recovery capability.

The central problem is how organizations can prepare for and manage recovery in a timely, secure, and resilient manner. The guide aims to help organizations identify critical resources, establish recovery objectives and criteria, develop tailored playbooks, coordinate stakeholders, and learn from recovery activities. It is guidance for planning and preparation; it is not an operational playbook for use during an active incident.

2. Proposed Framework and Methodology

Unlike an experimental research paper, NIST SP 800-184 is a standards-oriented technical guide. It does not present a newly trained model or a novel algorithm. Instead, it organizes recommended recovery practices into a lifecycle with tactical recovery during the event and strategic improvement after the event.

Component	Recommended approach
Preparation and planning	Identify critical people, processes, technologies, external services, and dependencies; define recovery objectives, roles, invocation criteria, and termination criteria.
Recovery playbooks	Create event-specific, organization-tailored procedures covering initiation, execution, termination, communications, and strategic follow-up.
Validation	Review plans with responsible personnel and conduct periodic exercises and tests to reveal operational gaps and validate realistic recovery targets.

Component	Recommended approach
Metrics and learning	Measure recovery performance, review milestones and assumptions, document lessons learned, and revise plans and security capabilities.

3. Technologies, Standards, and Techniques

The document is technology-neutral and does not prescribe a specific software stack, machine-learning model, or optimization algorithm. Its technical foundation is a set of cybersecurity risk-management and recovery practices, including the NIST Cybersecurity Framework (CSF), recovery playbooks, asset inventories, functional and security dependency maps, backup and restoration tools, integrity checks, recovery metrics, and testing exercises. It also references related NIST publications and security controls, including SP 800-53 Revision 4.

4. Key Recommendations and Findings

The guide emphasizes that recovery should be planned before an incident rather than improvised after one. Organizations should prioritize resources according to mission impact and dependencies, prepare to operate in a diminished state, and define who is authorized to initiate recovery. It recommends maintaining dependency information so restoration can be performed in an appropriate order, and ensuring that recovery does not undermine incident response or destroy forensic evidence.

Area	Key recommendation	Importance to recovery
Asset prioritization	Inventory mission-critical people, processes, systems, data, facilities, and external services.	Directs limited recovery resources toward the most important capabilities.
Dependencies	Maintain functional and security dependency maps and use them to determine restoration priority.	Helps avoid restoring dependent services before required infrastructure or foundational services.
Backup confidence	Check backup integrity and assess confidence in backup quality before restoration.	Reduces the risk of restoring encrypted, corrupted, or otherwise unsuitable backups.
Security validation	Coordinate with incident response and security personnel; verify restored assets are free of known indicators of compromise and meet the required security posture.	Prevents unsafe systems from being returned prematurely to normal operations.
Continuous improvement	Use exercises, tests, recovery metrics, and after-action reviews to update recovery plans.	Improves readiness and addresses weaknesses exposed by real events or simulations.

5. Destructive Malware / Ransomware Recovery Scenario

A particularly relevant part of the guide is its illustrative destructive-malware recovery scenario (Section 7). Before an incident, the organization is expected to maintain a ransomware recovery playbook, identify recovery personnel and critical assets, map functional and security dependencies, and test authorized backup and restoration tools. The guide also identifies confidence in backup quality as one factor relevant to restoration priority.

During recovery, the team inventories backup systems and available recovery points, checks that backups have not been encrypted, and uses the estimated infection timeline to identify candidate backups for integrity checking. Systems are restored from backups that have passed the acceptance criteria in the playbook. Restored assets are checked for indicators of compromise, validated for functionality and security posture, and approved before being returned to normal operation. The scenario also calls for continued monitoring after tactical recovery ends.

6. Limitations and Research Gaps

NIST SP 800-184 provides high-level guidance and recommended practices rather than an implementable algorithm for evaluating individual recovery points. Although it recommends integrity checks and refers to confidence in backup quality, it does not define a quantitative trust score, specify a formula for combining forensic evidence and threat intelligence, or rank backups using a formal scoring model. It also does not prescribe an agentic AI architecture or automated policy-enforcement mechanism.

The guide does not specify a standardized technical method for inferring the precise compromise window, measuring contamination probability, or recalculating recovery-point trust as new evidence arrives. Its dependency-map recommendation establishes the importance of restoration order, but it does not provide a detailed automated dependency-planning algorithm. These are areas where a project-specific implementation can extend the guidance.

7. Relevance to the Proposed Capstone Project

This publication is highly relevant to the project, **“Trust-Aware Agentic AI for Autonomous Cyber Incident Response and Resilient Recovery,”** because it directly establishes several principles that the proposed system intends to operationalize: backup integrity assessment, recovery-point confidence, dependency-aware restoration, security validation, and continuous monitoring.

The proposed system extends these principles by correlating security alerts, logs, cyber threat intelligence, attack timelines, service dependencies, and backup metadata to calculate a Recovery Trust Score (RTS) for candidate recovery points. It classifies each point as TRUSTED, UNCERTAIN, or UNTRUSTED, applies a policy gate before restoration, and generates a dependency-aware recovery plan. Human approval is required for high-impact actions, and the system can re-evaluate trust when new evidence becomes available.

The NIST guide therefore provides the recovery-planning foundation and practical requirements, while the capstone proposes a more explicit evidence-driven mechanism for ranking recovery points and orchestrating safe restoration. The RTS, trust states, agentic workflow, and policy gate are proposed project components; they are not algorithms supplied by NIST SP 800-184.

8. Conclusion

NIST SP 800-184 presents a comprehensive approach to cybersecurity event recovery through advance planning, customized playbooks, dependency mapping, backup validation, recovery metrics, and continuous improvement. Its ransomware scenario is especially useful because it explicitly recommends checking backup integrity, considering backup quality, identifying suitable recovery points, and validating restored systems before reintroducing them into production. For the proposed capstone, the publication serves as a foundational recovery guideline, while leaving room for a quantitative, trust-aware, and agentic approach to recovery point selection and execution.

Reference

[1] M. Bartock, J. Cichonski, M. Souppaya, M. Smith, G. Witte, and K. Scarfone, “Guide for Cybersecurity Event Recovery,” *NIST Special Publication 800-184*, National Institute of Standards and Technology, Gaithersburg, MD, USA, Dec. 2016, doi: 10.6028/NIST.SP.800-184.

Prepared for Capstone Project Phase-I · Review-1. This survey reviews one NIST technical publication; it is not the complete project literature survey.